

Resilience by Design:

Transforming Ransomware Response Into

Operational Resilience

Crystal Brock

Global Campus, Southern New Hampshire University

CYB-320: Incident Response and Investigation

Professor Bill Spettmann

April 9, 2026

Resilience by Design: Transforming Ransomware Response Into Operational Resilience

During the Incident

Managing the Incident

An incident response begins long before the first file is encrypted, because effective management centers on the alignment of organizational expectations with operational reality. When a ransomware incident occurs, identifying the affected assets requires a scope that reaches beyond hardware to include the systems of assets that define business logic. In our scenario, these primarily include the user's workstation and the critical financial files it accesses. Another serious impact surfaces in the compromise of identity and access management assets, such as Active Directory credentials, which the malware leverages to threaten enterprise data shares and the broader network fabric. Until the threat is neutralized, local backup appliances and other non-segmented departmental assets remain in a state of high-risk vulnerability.

Containment

Once assets are identified, containment must contend with how systems behave under the pressure of active propagation. We begin with physical network isolation of the infected host to sever its communication with Command and Control servers, hopefully preventing further lateral movement (NIST, 2012). This is followed by identity account suspension and application-level access revocation for Finance systems, creating a firebreak that may prevent the corruption of master network files (Liska, 2023). Technical teams must then enforce privilege de-escalation and endpoint health verification to ensure the malware cannot exploit administrative rights on adjacent hosts (NIST, 2020). Finally, user displacement to a verified clean environment ensures that work continues while the original subnet is treated as a digital crime scene.

Remediation

Remediation is the phase where we move from reactive containment to the purging of the threat. This process begins with forensic memory capture to identify active malicious processes in the volatile RAM (Johnson & Weiss, 2021). By performing malware scope mapping and signature analysis, analysts can trace the incident's blast radius across the network fabric. This is supplemented by decryption key research to find publicly available restoration solutions for the encrypted financial files (Liska, 2023). Once the scope is verified, credential neutralization is performed through mandatory password resets. The remediation concludes with threat eradication through a complete wipe and reimage of the hardware and a final backup integrity verification to confirm that cumulative backups remain pristine (NIST, 2012).

Recurrence Minimization

To minimize the possibility of recurrence, the organization must implement technical safeguards that remove human variability from the security equation. The primary recommendation is Endpoint Data Loss Prevention, which technically disables USB storage ports to eliminate the physical entry vector used in this incident (CIS, 2021). This is supported by transitioning to a Virtual Desktop Infrastructure, which treats physical workstations as disposable terminals (NIST, 2020). Furthermore, a data management and isolation policy should be established to ensure that master network shares are shielded from live-edit corruption. Finally, security awareness and training serve to ground these technical controls in a culture where employees recognize that efficiency should never bend formal safeguards.

Business Continuity

Effective business continuity recognizes that work must happen even when formal systems prove impractical. The recommended strategy for maintaining normal business

operations is the integration of employee relocation and manual transaction logging. By displacing staff to a clean environment, we protect the people aspect of the organization while the technology aspect is under repair. Because our current backup cycle allows for a 31-day data gap, the Finance department must rely on manual logging to bridge the distance between the last known good backup and the present day (NIST, 2010). This manual bridge ensures that transaction integrity is preserved for later reconciliation, allowing the enterprise to function despite the operational standstill of its primary network fabric.

Post Incident: Disaster Recovery

Failover Benefits and Impacts

Implementing failover infrastructure transforms disaster recovery from an exercise in compliance theater into a resilient operational reality. Failover provides physical and logical decoupling, creating hard boundaries that prevent ransomware from migrating to the recovery site. For the people involved, failover eliminates operational standstills and reduces the psychological friction caused by total system failure (Johnson & Weiss, 2021). Regarding process, utilizing VDI failover establishes a procedural 'Plan B' that allows staff to resume work via Zero-Trust verification (NIST, 2020). From a technology standpoint, automated restoration and verification ensure that the last known good state is applied consistently, reflecting how work actually happens rather than how it is diagrammed.

Backup Strategy Updates

A modernized backup strategy must address the gap between intent and operation by combining Tiered Backup Frequency with Active-Passive Cloud Mirroring. This update directly impacts the people in the organization by removing the burden of manual data reconciliation, as their work is synchronized in near real time. The process is refined by replacing outdated

monthly cycles with automated verification that aligns with the 3-2-1-1-0 backup rule (CIS, 2021). Finally, the technology of cloud mirroring achieves a near-zero Recovery Point Objective (RPO) through block-level replication (NIST, 2010). This technical shift ensures that organizational financials are protected against the slowly drifting procedures and outdated policies that often lead to data loss during a crisis.

References

Center for Internet Security (CIS). (2021). *CIS Critical Security Controls Version 8*.

<https://www.cisecurity.org/controls/v8>

Johnson, C. J., & Weiss, T. R. (2021). *Digital forensics and incident response: Incident response techniques and procedures (2nd ed.)*. Packt Publishing. <https://www.packtpub.com>

Liska, A. (2023). *Ransomware: Understand, prevent, and recover (1st ed.)*. O'Reilly Media.

<https://www.oreilly.com>

National Institute of Standards and Technology (NIST). (2010). *Contingency Planning Guide for Federal Information Systems* (Special Publication 800-34 Revision 1).

<https://csrc.nist.gov/publications/detail/sp/800-34/rev-1/final>

National Institute of Standards and Technology (NIST). (2012). *Computer Security Incident Handling Guide* (Special Publication 800-61 Revision 2).

<https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>

National Institute of Standards and Technology (NIST). (2020). *Zero Trust Architecture* (Special Publication 800-207). <https://csrc.nist.gov/publications/detail/sp/800-207/final>